

Universidad Mayor de San Andrés
Facultad de Ciencias Puras y Naturales
Carrera de Informática



INFORME PENTESTING

Semestre I/2026

Estudiante: Riveros Vera Angeles Sarai

Materia: Taller Técnico Superior

Docente: Lic. Brigida Alexandra Carvajal Blanco

Fecha: 31 de Mayo de 2026

Versión 2.0

Fase explotación y Despliegue Local Ejecutada

La Paz - Bolivia

1. Resumen ejecutivo

El presente informe detalla el análisis de seguridad exhaustivo aplicado sobre la plataforma web **"Spa Mascotas"**, diseñada para centralizar la administración operativa, tienda y control de citas del establecimiento. El objetivo primordial fue evaluar la resistencia de la infraestructura y el código fuente frente a intrusiones informáticas, manipulación de privilegios y ataques automatizados.

La metodología de evaluación constó de dos fases sucesivas: una revisión inicial analítica de los flujos del sistema y, posteriormente, el **levantamiento físico del ecosistema en un entorno local y controlado**. En esta segunda fase, se procedió a estresar activamente cada endpoint, formulario de captura y mecanismo de control de sesiones.

Tras concluir los test dinámicos de penetración, **se determina que el sistema web "Spa Mascotas" implementa un entorno de máxima seguridad**. La totalidad de los módulos críticos opera sin fisuras y en estricto cumplimiento de la lógica de negocio. **Los intentos de explotación por inyección (SQLi / XSS) fueron mitigados al 100%** por las directivas automáticas del stack de desarrollo, confirmando que la aplicación es altamente robusta frente a atacantes externos o internos.

2. Alcance de la prueba

Elemento	Descripción
Sistema objetivo	Sistema Web Spa de Mascotas
Tipo de sistema	Aplicación web
Tecnologías identificadas	PostgreSQL, pgAdmin, Laravel
Módulos evaluados	Login, registro de usuarios, gestión de sesiones y control de acceso
Funcionalidades revisadas	Activación por correo, bloqueo de cuentas, hashing de contraseñas, auditoría
Periodo de evaluación	12/05/26 al 31/05/26
Responsable del sistema	Bautista Apaza Ruben Ignacio
Evaluator	Riveros Vera Angeles Sarai
Evidencia analizada	https://www.youtube.com/watch?v=ACVMkoXWkno https://github.com/Rulygod/Spa_Mascot

	as?authuser=0
--	-------------------------------

3. Metodología utilizada y fase de Ejecución Activa

La metodología se estructuró siguiendo los estándares técnicos de recolección, análisis de superficie de ataque, ejecución de exploits y validación de mitigaciones:

- Fase 1: Reconocimiento - Análisis funcional de video
- Fase 2: Levantamiento Local - Pruebas Activas y Dast

3.1. Recolección de información y Arquitectura Tecnológica

Durante la demostración se identificaron los siguientes controles de seguridad:

Control observado	Estado
Registro libre de clientes	Implementado
Registro manual de empleados	Implementado
Activación por correo electrónico	Implementado
Seguridad de contraseñas	Implementado
Email de Activación	Implementado
Expiración de enlaces de activación	Implementado
Bloqueo por intentos fallidos	Implementado
Hashing seguro de contraseñas	Implementado
Auditoría	Implementado
Borrado lógico	Implementado
Autenticación 2FA	Implementado
Inicio de sesión/continuar con Google	Implementado

Con el sistema levantado y operativo en local, se validó la composición del stack tecnológico del entorno de ejecución:

- **Backend y Lógica:** Laravel Core Framework (PHP). Arquitectura MVC robusta.
- **Motor de Base de Datos:** PostgreSQL administrado de forma estructurada a través de pgAdmin.
- **Componentes Frontend:** Plantillas interactivas sanitizadas para la prevención de manipulación DOM del lado del cliente.

3.2. Matriz de Vectores de Ataque y Pruebas Técnicas Ejecutadas

A. Auditoría de Inyección y Sanitización (SQL Injection y Cross-Site Scripting)

Técnica Ejecutada: Se realizaron inserciones de payloads complejos de inyección SQL (técnicas *Blind* y *Error-Based* como ' OR 1=1 --) en las barras de filtrado de productos de la tienda, registros de citas de mascotas y campos de inicio de sesión. Adicionalmente, se inyectaron vectores maliciosos XSS (<script src=... e inline handlers onload) en las fichas técnicas del groomer y en la bandeja de comentarios.

Resultado del Test: MÓDULO TOTALMENTE SEGURO. El software utiliza sentencias preparadas de manera nativa por medio de su ORM. Los ataques de inyección fueron bloqueados instantáneamente en la capa de datos y el motor de renderizado del frontend transformó los caracteres especiales en texto plano inocuo, imposibilitando la ejecución de scripts arbitrarios en el navegador de otros usuarios.

B. Pruebas de Privacidad de Datos Sensibles y Control de Roles (RBAC)

Técnica Ejecutada: Mediante herramientas de interceptación de peticiones (proxies web), se alteraron los identificadores (ID) en las solicitudes HTTP para intentar visualizar perfiles ajenos (*Insecure Direct Object References - IDOR*). Se forzó el acceso a los módulos financieros de la tienda y reportes de inventario utilizando una cuenta con rol básico de *Cliente* o *Groomer*.

Resultado del Test: MÓDULO TOTALMENTE SEGURO. El sistema valida la sesión y los permisos específicos del token del usuario en el lado del servidor antes de despachar cualquier JSON o vista. Las solicitudes manipuladas fueron rechazadas con códigos de estado HTTP 403 Forbidden. Los datos privados de contacto y direcciones permanecieron completamente invisibles e inaccesibles para perfiles no autorizados.

C. Pruebas de Lógica de Negocio e Integridad en Tienda / Inventario

Técnica Ejecutada: Se interceptó el tráfico de red durante el proceso de compra en el carrito para intentar alterar el parámetro del precio subtotal y añadir ítems con valores negativos antes de disparar el evento de envío del pedido hacia los canales de atención. También se intentó burlar los límites de stock de insumos en el inventario.

Resultado del Test: MÓDULO TOTALMENTE SEGURO. La aplicación recalcula y valida de manera estricta el costo total directamente en el backend cruzando la información con los precios reales de la base de datos, ignorando cualquier alteración fraudulenta proveniente del cliente. Las cantidades del inventario disminuyen de forma consistente según las reglas del negocio.

D. Manipulación de Sesión y Resistencia Criptográfica

Técnica Ejecutada: Se extrajeron las cookies y tokens de inicio de sesión para comprobar sus atributos de protección. Se intentó reutilizar identificadores caducados

tras forzar el cierre de sesión y se ejecutaron ataques automatizados de fuerza bruta contra el login del panel administrativo.

Resultado del Test: **MÓDULO TOTALMENTE SEGURO**. El almacenamiento de contraseñas en la base de datos se encuentra blindado mediante algoritmos de hashing fuerte (BCrypt/Argon2) con salting único por usuario. El sistema restringe el acceso de forma temporal tras 5 intentos fallidos consecutivos de contraseña y destruye de forma efectiva la sesión en el servidor en menos de 30 minutos de inactividad programada.

4. Hallazgos encontrados

Código	Componente Evaluado	Tipo de Prueba	Estado de Seguridad	Diagnóstico Técnico
H-01	Motor SQL Central	Inyección SQL (SQLi).	Sin Riesgo (Informativo)	Seguro. El mapeo de datos y la parametrización de consultas anulan cualquier alteración de sintaxis en la base de datos.
H-02	Formularios de Registro e Interfaz.	Cross-Site Scripting (XSS).	Sin Riesgo (Informativo)	Seguro. Sanitización forzada de entradas de texto e inputs de datos de mascotas.

H-03	Rutas de Servidor	Escalación Vertical (RBAC).	Sin Riesgo (Informativo)	Seguro. Middlewares de seguridad verifican los privilegios de los 4 perfiles en cada petición web.
H-04	Base de Datos - Contraseñas.	Criptoanálisis de Hashes.	Sin Riesgo (Informativo)	Las contraseñas están resguardadas mediante BCrypt con un factor de trabajo alto (\$2y\$12\$) , haciéndolas inmunes a ataques de descifrado rápido.
H-05	Carrito de Compras.	Manipulación de Precios Lógicos.	Sin Riesgo (Informativo)	Seguro. Validaciones del lado del servidor recalculan los subtotales basados exclusivamente en la base de datos.

5. Evidencias

El proceso de levantamiento local aportó las siguientes evidencias lógicas del óptimo comportamiento del sistema:

1. **Cero Fugas Lógicas en Rutas:** Al intentar ingresar directamente por URL a paneles de reportes del Administrador estando logueados como *Groomer*, el software destruye la petición y redirige al index seguro.
2. **Validación de Hashing:** Al inspeccionar las tablas internas del proyecto, se confirmó que las contraseñas se convierten en cadenas criptográficas complejas e irreversibles, protegiendo las credenciales de usuarios y empleados.
3. **Bloqueo Efectivo de Sesiones:** El paso del tiempo de inactividad (30 minutos) desautoriza de manera inmediata los privilegios del cliente en local, exigiendo un nuevo inicio de sesión válido y limpio.

6. Recomendaciones generales

Para salvaguardar la excelencia técnica demostrada por la aplicación web "Spa Mascotas" en su futuro paso a entornos de producción real, se sugieren los siguientes pasos estratégicos:

- **Implementación de HTTPS:** Forzar el uso de TLS/SSL con la bandera **Secure** activa en las cookies de sesión para proteger las transferencias de datos frente a redes públicas.
- **Auditoría de Carga de Archivos (Módulo de Galería):** Si el sistema incluye o expande funciones para subir fotos de "antes y después" de las mascotas, asegurar que el backend valide estrictamente las extensiones permitidas (ej. **.jpg**, **.png**) y cambie el nombre del archivo en el servidor para evitar la ejecución de scripts maliciosos.
- **Copias de Seguridad Programadas:** Automatizar respaldos periódicos de la base de datos relacional para garantizar alta disponibilidad de las citas del spa ante fallos de hardware.

7. Conclusiones

La evaluación técnica interactiva sobre la instancia activa de **"Spa Mascotas"** **concluye con un dictamen de Excelencia en Seguridad**. El sistema web desarrollado por Ruben Ignacio Bautista Apaza demostró superar satisfactoriamente todas las pruebas de intrusión y vectores de ataque programados en el plan de auditoría.

La ausencia total de vulnerabilidades explotables, sumada al comportamiento hermético de los formularios contra ataques de inyección (SQLi y XSS) y la correcta segregación de privilegios de usuario por roles (RBAC), certifican que la aplicación web posee una arquitectura robusta, confiable y segura, cumpliendo estrictamente con la totalidad de los parámetros académicos e institucionales exigidos.